

Lezione 1 – Cyber-Physical Security

Introduzione alla Cyber Security

Dario Stabili

Corso di Laurea Triennale in Ingegneria Informatica – Sede di Mantova
Dipartimento di Ingegneria “Enzo Ferrari” (DIEF)
Università degli Studi di Modena e Reggio Emilia
a.a. 2026–2027



UNIMORE
UNIVERSITÀ DEGLI STUDI DI
MODENA E REGGIO EMILIA

Cos'è per voi la Sicurezza Informatica?

Ve l'avevo detto che il corso sarebbe stato interattivo...



L'interpretazione dell'AI

Giusto perché ogni tanto è bello far fare delle slide a qualcun'altro



L'interpretazione del docente

Forse un pelo stereotipata ma decisamente più realistica della precedente



L'interpretazione del docente

Forse un pelo stereotipata ma decisamente più realistica della precedente



L'interpretazione del docente

Forse un pelo stereotipata ma decisamente più realistica della precedente



Trivia time

Prima lezione, prendiamola con calma

Sicurezza informatica nei media: fake or real?

- Codice: Swordfish
- The Italian Job
- The Fate of the Furious
- Wargames
- NCIS
- The Matrix Reloaded
- Iron Man 2
- Avengers: Age of Ultron
- Mr. Robot

Cos'è la Sicurezza?

Mito vs. Realtà

Lo stereotipo mediatico

- L'hacker con il cappuccio: Un individuo solitario che digita a raggica su un terminale in un seminterrato, bucando sistemi governativi in 30 secondi
- La percezione magica: L'idea che la sicurezza sia un software antivirus installato o un perimetro rigido impene-trabile.

Cos'è la Sicurezza?

Mito vs. Realtà

Lo stereotipo mediatico

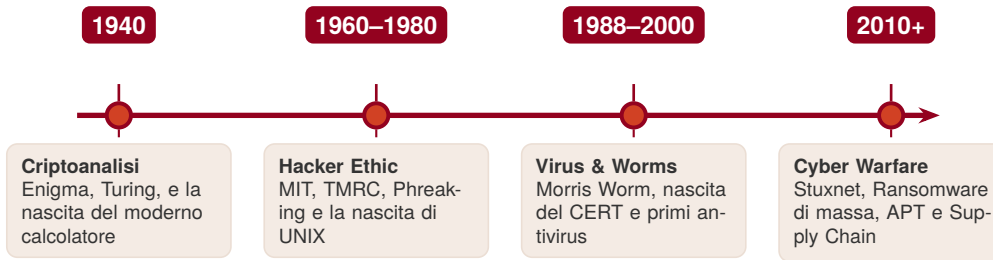
- L'hacker con il cappuccio: Un individuo solitario che digita a raggica su un terminale in un seminterrato, bucando sistemi governativi in 30 secondi
- La percezione magica: L'idea che la sicurezza sia un software antivirus installato o un perimetro rigido impene-trabile.

La realtà dei fatti

- Un lavoro di squadra ordinato: Team di sviluppatori, analisti di rete, sistemisti, penetration tester, security analyst, incident responder, che collaborano tra loro per garantire la sicurezza di un sistema.
- Un processo continuo: Disciplina ingegneristica, gestione del rischio, contrasto costante a errori umani e architetturali

La Mappa Temporale

Absolute points



La Superficie d'Attacco

I tre bersagli

- **Hardware e Firmware**

Side channels, vulnerabilità fisiche, apparati industriali SCADA/PLC e dispositivi embedded dalle scarse risorse computazionali

- **Software & Protocolli**

Bug logici, buffer overflow, librerie compromesse, errata gestione di authN/authZ e 0-day

- **Il Fattore Umano**

Social engineering, pretexting, distrazione operativa e mancato rispetto delle procedure di sicurezza

La Nascita della Criptoanalisi

Come le necessità belliche e la crittografia hanno generato i primi calcolatori moderni

Enigma (1926) & Arthur Scherbius

La macchina cifrante a rotori

Brevettata nel 1918 dall'ingegnere tedesco Arthur Scherbius e adottata dalla marina nel 1926, Enigma sostituiva i cifrari cartacei con un circuito elettromeccanico a rotori intercambiabili. Ogni pressione di tasto faceva avanzare i rotori, modificando l'alfabeto di sostituzione e generando milioni di combinazioni ritenute inviolabili.



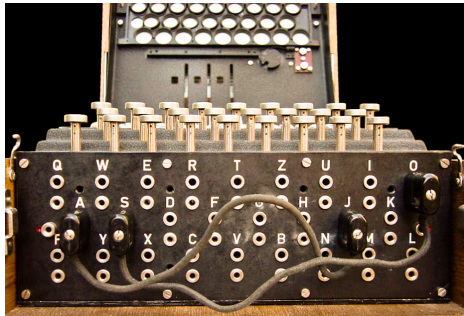
L'Enigma militare & La Plugboard

La Plugboard (Steckerbrett)

- La versione adottata dalla Wehrmacht aggiunse un pannello frontale che scambiava coppie di lettere prima e dopo il passaggio nei rotori.
- Il numero di configurazioni possibili superò i 150 trilioni, rendendo l'attacco a tentativi manuali impossibile.

La Chiave del Giorno

- I manuali di codifica cambiavano quotidianamente l'ordine dei rotori, gli anelli e i collegamenti della plugboard.
- L'assoluta fiducia nella complessità algoritmica portò a sottovalutare gli errori operativi umani.



La rottura Polacca

Marian Rejewski

La Teoria dei Gruppi (1932)

- **L'Approccio Matematico:** Marian Rejewski, con Henryk Zygalski e Jerzy Rozycki, non usò linguisti ma la teoria delle permutazioni per dedurre la circuiteria interna dei rotori senza averne mai visto uno.
- **La Bomba Crittologica (1938):** Progettarono una macchina automatica a sei motori per testare rapidamente le posizioni dei rotori prima del cambio chiave giornaliero.

La Collaborazione con gli Alleati (1939)

- **L'Evoluzione a 4 Rotori:** Nel 1938 i nazisti aggiunsero rotori, vanificando la prima macchina polacca per mancanza di risorse economiche.
- **Il Passaggio di Consegne:** Poco prima dell'invasione della Polonia, i polacchi consegnarono progetti e repliche di Enigma a Francia e Gran Bretagna.

Bletchley Park & Alan Turing

La Macchina "Bombe" (1939-1940)

- **Alan Turing & Gordon Welchman:** Progettarono a Bletchley Park una macchina elettromeccanica capace di escludere contemporaneamente milioni di combinazioni errate.
- **Harold "Doc" Keen:** Ingegnere capo della BTM che trasformò i calcoli teorici di Turing in hardware operativo e affidabile.

Known Plaintext Attack

- **Sfruttare le Routine:** I messaggi tedeschi contenevano formule ripetitive fisse (es. bollettini meteo "WETTER" o saluti ufficiali).
- **Efficienza** **Algoritmica:** Conoscendo una porzione di testo in chiaro, la macchina isolava le contraddizioni elettriche invece di procedere a forza bruta cieca.

Colossus (1944)

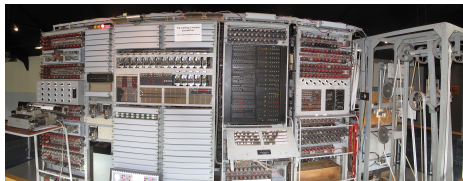
L'alba del moderno calcolatore

- **Il Cifrario di Lorenz (SZ40/42)**

- Utilizzato dal comando supremo nazista; non era un'Enigma tattica, ma una telescrivente cifrante a 12 rotori.
- Progettato da Tommy Flowers con oltre 1.500 valvole termoioniche, programmabile tramite switch e con lettura a nastro ottico.

- **L'Eredità Informatica**

- Colossus ha dimostrato al mondo che l'elettronica poteva elaborare logica simbolica a velocità impensabili.
- Dalla rottura dei codici è nata la moderna architettura di calcolo elettronico e la crittografia scientifica.



Origine dell'Hacking

Dall'esplorazione dei modellini ferroviari del MIT ai primi scherzi telefonici e alla nascita dei sistemi operativi.

MIT Tech Model Railroad Club

(The wellspring of hacker culture)

● Dai Trenini ai Calcolatori

- Studenti e ricercatori del MIT costruivano circuiti a relè complessi per automatizzare gli scambi del plastico ferroviario
- **Il concetto di “Hack”**: Qualsiasi modifica ingegnosa e non convenzionale atta a migliorare le prestazioni di un sistema HW o a comprenderne la natura profonda era considerata “h”

● L’Incontro con il TX-0 (1955)

- I membri del TMRC ottennero l’accesso notturno al mainframe TX-0, trasferendo la passione dei circuiti al software.
- Da questo gruppo nacquero i pionieri che svilupparono i primi videogiochi, editor di testo e compilatori



I Pionieri del TMRC & MIT

Dennis, Kotok e Deutsch

- **Jack Dennis**

Co-inventore del sistema operativo MULTICS (1964) assieme a Corbato e Fano, che ha posto le basi architettureali per UNIX e GNU/Linux.

- **Alan Kotok**

Coautore di Spacewar! (1960), uno dei padri del DEC PDP-1 e successivamente tra i fondatori del World Wide Web Consortium (W3C).

- **Peter Deutsch**

Autore del LISP per PDP-1 a soli 17 anni, pioniere di Smalltalk (compilatore JIT), creatore di Ghostscript e autore di RFC fondamentali.

Phone Phreaking

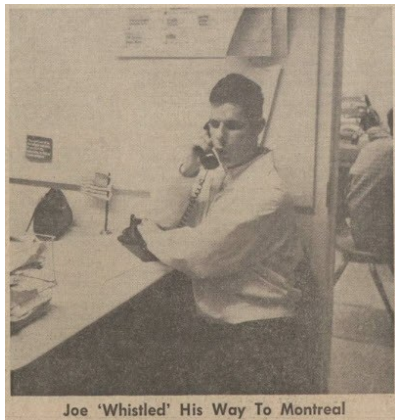
Joybubbles e i 2600Hz

- **Josef Carl Engressia Jr. (1956)**

- Ragazzo non vedente con una straordinaria sensibilità acustica, scopre per caso fischiando che una precisa frequenza sonora sblocca la linea telefonica.
- Il segnale (a 2600Hz) indicava alle centrali elettromeccaniche AT&T che la chiamata era terminata, aprendo la modalità di routing per chiamare ovunque gratis.

- **L'Esplorazione della rete telefonica**

- Negli anni '60 la rete telefonica era l'unico network globale interconnesso esistente.
- Non rubare soldi, ma mappare e comprendere gli switch telefonici e i toni multifrequenza internazionali → **filosofia Phreak**



John Draper

Cap'n Crunch & La Blue Box

- **John Draper**

- Scopre che il fischietto giocattolo in regalo nelle scatole dei cereali Cap'n Crunch emette esattamente un tono puro a 2600Hz
- Progetta circuiti oscillatori portatili per emettere toni e controllare gli swtich telefonici a piacere: la Blue Box

- **L'Influenza sui Fondatori di Apple**

- Steve Wozniak e Steve Jobs iniziarono la loro prima attività commerciale costruendo e vendendo le Blue Box di Draper nei campus universitari
- L'esplosione della rete telefonica iniziata da Joybubbles sfociò nell'attenzione dell'FBI e nei primi arresti per frode e telecomunicazioni

Il fischietto e Wozniak con la Blue Box



Le Prime Vulnerabilità di Sistema

(1963 - 1965)

- **1963: War Dialing su Harvard PDP-1**

- Gli studenti del MIT riprogrammano da remoto il PDP-1 di Harvard per comporre a raffica prefissi telefonici alla ricerca di altri modem collegati.
- Nasce il concetto di scansione automatica di porte/linee e una bolletta telefonica memorabile per l'ateneo

- **1965: Il Bug delle Password nel CTSS**

- David Matthews del MIT scopre che l'apertura contemporanea dell'editor di testo su IBM 7094 scambiava il file delle password con il "Messaggio del Giorno".
- **Risultato:** All'avvio, ogni terminale mostrava a schermo l'elenco completo di tutti gli hash e le password di sistema.

Social Engineering, Virus & Il Collasso di ARPANET

Dalla manipolazione psicologica di Kevin Mitnick all'esplosione dei primi malware autoreplicanti di rete.

Kevin David Mitnick (1963-2023)

(Il primo social engineer)

- Consulente di sicurezza, cracker.
- Pioniere di due tecniche di attacco.
 - Social Engineering: manipolazione psicologica delle persone atta a rivelare dati sensibili.
 - Dumpsterdiving: ricerca di dati sensibili nei rifiuti.
- **1979**: viola Ark (DEC) e ruba il software della Digital. Viene arrestato nel 1988.
- **1982**: viola la rete militare del NORAD.
- **1992**: rilasciato, viola il sistema voice mail di Bell. Si dà alla latitanza.
- **1995**: viene nuovamente arrestato.



Elk Cloner (1981)

La Nascita del termine "Virus"

- **Elk Cloner su Apple II (1981)**

- Rich Skrenta (15 anni) crea un software per Apple II che monitora le operazioni di lettura/scrittura e si copia nel boot sector di ogni floppy inserito.
- Al 50° avvio del dischetto infetto, il programma si manifestava con una poesia. Si diffuse a macchia d'olio tramite lo scambio di giochi piratati.

- **Fred Cohen & La Teoria Scientifica (1984)**

- Nel paper "Computer Viruses - Theory and Experiments" formalizza il concetto di codice in grado di infettare altri programmi.
- Cohen dimostra matematicamente che il problema di riconoscere se un generico programma sia un virus è indecidibile (riduzione al problema della terminazione di Turing).

Christmas Tree EXEC & I Primi Antivirus

- **Christmas Tree EXEC (1987)**

- Scritto in REXX da uno studente tedesco; disegnava un albero di Natale ASCII e si auto-inviava a tutti i contatti email.
- Mandò in blocco le reti universitarie EARN, BITNET e la rete aziendale interna IBM VNET.

- **La Risposta: I Primi Antivirus (1987-1991)**

- **Bernd Fix & G Data (1987):** Primi tool di disinfezione specifici e nascita delle prime suite commerciali per Atari ST e PC.
- **F-PROT (1991):** Introduce i due pilastri della scansione moderna: database delle firme dei binari (a riposo) ed euristiche comportamentali (in esecuzione).

Il Morris Worm (1988)

ARPANET in ginocchio

- **Robert Tappan Morris (Cornell)**

- Un programma (da lui stesso ribattezzato “worm”) scritto per mappare le dimensioni di Internet sfruttando falle note in sendmail, fingerd e rsh.
- Per evitare che i nodi mentissero dicendo di essere già infetti, il worm si reinstallava comunque una volta su sette, generando copie infinite e saturando la memoria.

- **L’Impatto & Il Collasso del 10% di Internet**

- Circa un decimo dell’intera rete ARPANET andò in stallo completo in poche ore, con danni stimati fino a 98 milioni di dollari.
- Morris fu la prima persona processata e condannata ai sensi del Computer Fraud and Abuse Act:
 - 400 ore di servizi sociali
 - \$ 10k di multa
 - 3 anni di libertà vigilata

La risposta Istituzionale: Nascita del CERT (1988)

● La Creazione del CERT (1988)

- In risposta ai danni del Morris Worm (circa 98 milioni di dollari), la Defense Advanced Research Projects Agency (DARPA) istituisce il CERT (Computer Emergency Response Team) presso la Carnegie Mellon University.
- Nasce il concetto moderno di CERT: una struttura centralizzata di coordinamento e risposta agli incidenti di sicurezza informatica su larga scala.

● 1989: AIDS Trojan (Primo Ransomware)

- Joseph Popp invia via posta 20.000 floppy disk a medici contenenti informazioni sull'AIDS.
- Dopo 90 riavvii, il trojan cifrava i file e chiedeva 189\$ o 378\$ da inviare tramite assegno bancario a una casella postale a Panama.

Collettivi, Hacktivism & Controversie Legali

Dalla nascita dei grandi gruppi hacker negli anni '80 alla pubblicazione clandestina di codice e alle battaglie sul copyright.

I Collettivi Sotrici

CCC & Legion of Doom

- **Chaos Computer Club (1981, Germania)**

- Fondato a Berlino per difendere la libertà di comunicazione e l'etica della trasparenza dell'informazione.
- Gestisce l'evento annuale di hacker (Chaos Communication Congress) e diritti digitali più influente e partecipato d'Europa.

- **Legion of Doom & Phrack (1984-1985)**

- Il gruppo hacker underground più prestigioso degli anni '80 (ft. Lex Luthor e Erik Bloodaxe)
- Nasce la rivista Phrack, una tra le più longeve e influenti testate online di hacking, punto di riferimento per l'analisi tecnica di exploit e architecture, considerata più influente dei journal accademici dell'epoca.

I Collettivi Sotrici

cDc & Back Orifice

- **Cult of the Dead Cow (cDc, 1984, USA)**

- Gruppo hacker attivista statunitense (Texas), noto per il forte impegno sociale e politico e per aver inventato l'alfabeto leet (31337, per "elite").
- Nasce il concetto di **Hacktivism** – termine coniato dal membro *Omega* per indicare l'uso politico e sovversivo del ciberspazio per promuovere cause politiche e sociali a supporto dei diritti umani.

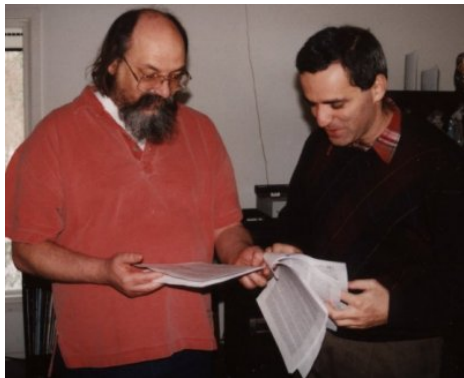
- **Back Orifice (1998, Sir Dystic)**

- Rilasciato pubblicamente a DEF-CON per dimostrare le vulnerabilità critiche di Windows 95/98. Uno dei primi RAT (Remote Access Trojan) gratuiti e open source.
- Ha segnato il passaggio definitivo all'uso di strumenti di amministrazione remota per scopi di attacco e sorveglianza.

Kenneth Lane “Ken” Thompson

(Trusting Trust, 1983)

- Informatico.
- **1969:** coautore di UNIX (con Dennis Ritchie).
- **1983:** vince il premio Turing (Nobel dell'Informatica) insieme a Dennis Ritchie.
- Lectio Magistralis del premio Turing: “Reflection Trusting Trust”: ... *Non puoi fidarti di codice che non hai creato tu stesso per intero... Nessun livello di verifica del codice sorgente ti proteggerà da un compilatore compromesso...*



DEFCON e il caso Dmitry Sklyarov

Primi anni 2000

● DEFCON (1993, USA)

- Fondata da Jeff Moss (The Dark Tangent) a Las Vegas, è divenuta il punto d'incontro primario tra ricercatori di sicurezza, agenzie federali e hacker.
- Da evento “Underground” a “Mainstream”. Luogo di scontro e confronto tra ricerca etica e regolamentazione governativa. Molti talk interessanti sono disponibili online sul canale youtube DEFCONConference

● L'Arresto di Dmitry Sklyarov (2001)

- Ricercatore russo di ElcomSoft che presenta a DEFCON le falle di protezione del formato eBook di Adobe.
- Arrestato dall'FBI su denuncia di Adobe ai sensi del Digital Millennium Copyright Act. Rilasciato dopo mobilitazioni di massa della EFF.

La Transizione al Crimine di Massa & Alla Cyber-Warfare

Dall'ingegneria sociale via posta elettronica agli attacchi contro interi stati sovrani e infrastrutture fisiche.

I Macro Virus

Melissa e Kournikova

- **Melissa (1999, David L. Smith)**

- Il primo macro virus di massa: nascosto all'interno di documenti Word allegati via email, si diffondeva leggendo la rubrica di Outlook ed inviando una copia di sé a 50 contatti.
- Blocca i server di Microsoft e Intel.
- Smith fu condannato a 10 anni (poi ridotti a 20 mesi come collaboratore FBI).

- **Anna Kournikova Worm (2001, Jan De Wit)**

- Script VBScript camuffato da presunta foto provocante della famosa tennista.
- L'autore, un ventenne olandese, si costituì spontaneamente.
- Fu condannato a 150 ore di servizi sociali e poi assunto come tecnico dal comune.

2007: Attacco all'Estonia

La Prima prova di Cyberwar

● Perché l'Estonia

- Uno dei paesi più avanzati al mondo per infrastruttura digitale: servizi bancari online, parlamento paperless e voto elettronico.
- Lo spostamento di un monumento ai caduti sovietici scatena tensioni diplomatiche con la Russia.
- (casualmente, qualche giorno dopo) Botnet globali inondano di traffico banche, media, telecomunicazioni e server governativi estoni per settimane → **L'Estonia si ritrova isolata digitalmente per giorni.**
- Primo caso in cui un'offensiva digitale porta la NATO a mobilitare esperti di cyber-difesa e a fondare il CCDCOE a Tallinn.



Operation Aurora

L'era degli APT

- **L'Intrusione a Google e altri Tech Giants**

- Google scopre e denuncia pubblicamente attacchi coordinati e persistenti (APT: Advanced Persistent Threat) condotti da attori statali cinesi.
- **Obiettivo:** Furto di proprietà intellettuale, accesso ai repository di codice sorgente e monitoraggio degli account di dissidenti politici.

- **Il Salto di Paradigma**

- Oltre **20 grandi multinazionali colpite**, tra cui Adobe, Northrop Grumman, Dow Chemical e Morgan Stanley.
- Ha costretto le aziende a comprendere che non stavano affrontando ragazzini, ma organizzazioni militari sponsorizzate da governi → **Nascita della Threat Intelligence.**

2010: Stuxnet

Attacco a Infrastrutture Industriali

- **Il Sabotaggio delle Centrifughe di Natanz**

- Malware progettato per colpire i PLC industriali Siemens S7-300 che controllavano le centrifughe di arricchimento dell'uranio in Iran.
- Modificava la velocità di rotazione per rompere i rotori, mostrando contemporaneamente ai monitor degli operatori valori di telemetria perfetti.

- **La Complessità del Malware**

- Sfruttava **4 vulnerabilità zero-day** (un record per l'epoca).
- Si diffondeva tramite chiavette USB infette, aggirando le difese perimetrali di reti air-gapped.
- Aveva una "logic bomb": restava dormiente per mesi prima di attivarsi e distruggere gli impianti.

2015: Attacco a rete elettrica Ucraina

Milioni di persone senza elettricità alle porte del Natale

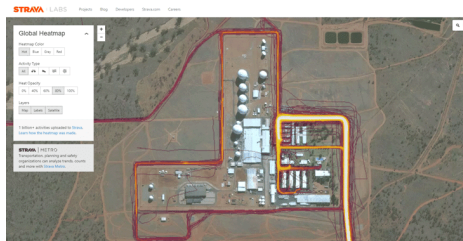
- **Dicembre 2015:** Attacco cibernetico coordinato ai sistemi informativi di tre società ucraine di distribuzione elettrica.
- 230.000 persone rimangono senza corrente elettrica per 6 ore.



2018: Il disastro “Strava”

Non tanto un attacco quanto una grave mancanza di sensibilità in materia di privacy

- **Novembre 2017:** Strava, una popolare applicazione di fitness tracking, rilascia in pubblico la “heatmap” di tutti i percorsi svolti dai suoi utenti del 2017.
 - 13.000 miliardi di coordinate GPS relative a punti di percorsi di allenamento (tipicamente, corsa)



2018: Il disastro “Strava”

Non tanto un attacco quanto una grave mancanza di sensibilità in materia di privacy

- **Gennaio 2018:** uno studente ventenne della National University di Canberra, Nathan Ruser, partendo dai percorsi di allenamento dei militari riesce ad identificare le installazioni militari segrete di mezzo mondo.

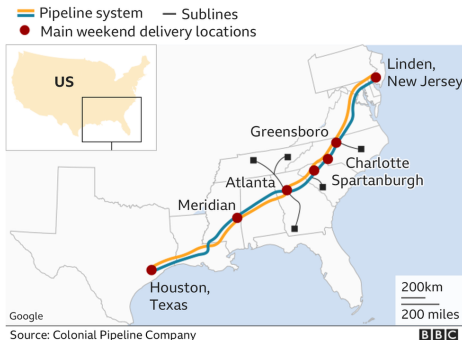


2021: Colonial pipeline hack

Un attacco diretto all'economia USA del petrolio

- **Maggio 2021:** Colonial Pipeline, un oleodotto che serve gran parte del sud-est degli USA, è vittima di un ransomware.
- Viene richiesto il pagamento di 75 bitcoin (4.4M USD) per l'ottenimento delle chiavi di decifratura.
- Il sistema è stato ripristinato una volta pagato il riscatto.

Colonial Pipeline system map



2015: Ashley Madison data leak

Non solo furto di dati ma conseguenze devastanti per le persone

- **Luglio 2015:** il sito di incontri online “Ashley Madison” è violato.
 - Il sito si rivolge ad una clientela già sposata o in una relazione, promuovendo di fatto l'adulterio.
- Il gruppo attaccante (“The Impact Team”) minaccia di divulgare le credenziali degli utenti se il sito non viene chiuso.
- **18-20 agosto:** 25 GB di dati (incluse le credenziali degli utenti) è divulgato online.
- Diversi utenti del sito si suicidano.

TIME'S UP!

Avid Life Media has failed to take down Ashley Madison and Established Men. We have explained the fraud, deceit, and stupidity of ALM and their members. Now everyone gets to see their data.

Find someone you know in here? Keep in mind the site is a scam with thousands of fake female profiles. See ashley madison fake profile lawsuit; 90-95% of actual users are male. Chances are your man signed up on the world's biggest affair site, but never had one. He just tried to. If that distinction matters.

Find yourself in here? It was ALM that failed you and lied to you. Prosecute them and claim damages. Then move on with your life. Learn your lesson and make amends. Embarrassing now, but you'll get over it.

Any data not signed with key 6E50 3F39 BA6A EAAD D81D ECFF 2437 3CD5 74AB AA38 is fake.

[Impact Team's statement on the release](#)

[Impact Team's PGP signature for the released statement](#)

[Impact Team's PGP Key](#)

[Torrent for the released data](#)

Ransomware e Supply Chain

Dall'epidemia globale di WannaCry e NotPetya ai cavalli di Troia negli aggiornamenti software e nelle librerie condivise.

2017: WannaCry

Grazie, ETERNALBLUE!

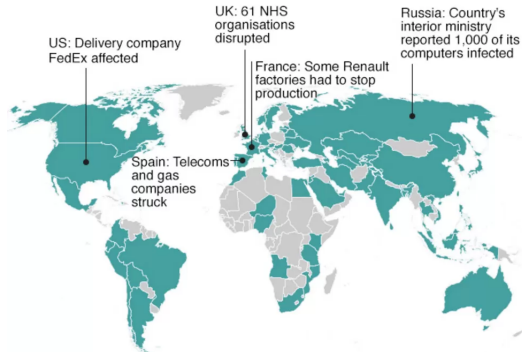
- **Maggio 2017:** il ransomware WannaCry si diffonde su scala mondiale, criptando e rendendo inutilizzabili centinaia di migliaia di macchine operanti servizi di pubblica utilità.
 - Cifra oltre 200.000 computer in 150 paesi in poche ore, bloccando gli ospedali del servizio sanitario britannico (NHS), FedEx e Renault.
- Viene chiesto un riscatto in bitcoin per lo sblocco.
- Utilizza l'exploit ETERNALBLUE (classificato da NSA) per diffondersi.



Wannacry

Diffusione dopo poche ore

Countries hit in initial hours of cyber-attack



*Map shows countries affected in first few hours of cyber-attack, according to Kaspersky Lab research, as well as Australia, Sweden and Norway, where incidents have been reported since

Source: Kaspersky Lab's Global Research & Analysis Team

BBC

Il blocco di Wannacry

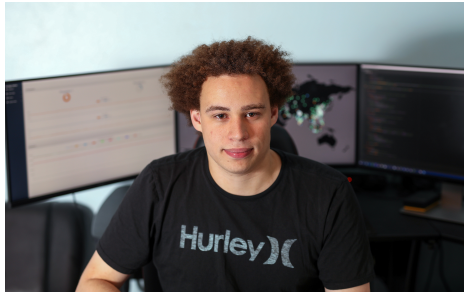
(One comic strip is worth a thousand words)



Marcus Hutchins (1994-)

AKA “MalwareTech”. Blocca WannaCry e viene imprigionato

- **12 maggio 2017:** il ricercatore inglese (all'epoca, 22enne), nota un nome di dominio hardcoded nel codice di WannaCry e lo registra per 10\$.
- Il dominio fungeva da kill-switch anti-sandbox e blocca l'epidemia mondiale
- **Agosto 2017:** Hutchins viene invitato a DEF-CON per presentare l'analisi del malware ma viene arrestato con l'accusa di aver scritto il malware bancario Kronos nel 2014/2015.
- **Luglio 2019:** Hutchins è condannato ad un anno di libertà vigilata.



2017+: NotPetya, HermeticWiper

La rivalsa dei ransomware

● NotPetya (Giugno 2017)

- Mascherato da ransomware, era in realtà un'arma distruttiva (wiper) progettata per distruggere irreversibilmente il Master Boot Record (MBR).
- Inoculato tramite il software fiscale ucraino M.E.Doc, mise in ginocchio Maersk, Merck e la logistica mondiale
- Danni stimati tra 5 e 10 miliardi di dollari.

● Hermetic Wiper (Febbraio 2022)

- Rilasciato il 23 febbraio 2022 contro agenzie e istituzioni finanziarie ucraine
- Bypassava i controlli di Windows per frammentare i settori fisici dei dischi e renderli irrecuperabili prima dell'attacco sul campo.

2022: l'Hacking a Twitter

Social Engineering

- **ByPass di Tool Amministrativi**

- Graham Ivan Clark (17 anni) con due complici, manipola via telefono i dipendenti dell'helpdesk interno di Twitter fingendosi personale IT.
- Ottiene l'accesso al pannello di amministrazione interno con facoltà di reimpostare le credenziali di qualsiasi profilo.

- **130 Account Verificati Compromessi**

- Pubblica messaggi fake da account di Barack Obama, Elon Musk, Joe Biden, Bill Gates e Apple promettendo di raddoppiare i Bitcoin inviati.
- Guadagno di appena 110.000\$, ma dimostrazione sconcertante della vulnerabilità strutturale delle grandi piattaforme globali.

2022: I'Hacking a Twitter

Social Engineering



Apple
@Apple

We are giving back to our community. We support Bitcoin and we believe you should too!

All Bitcoin sent to our address below will be sent back to you doubled!

bc1qxy2kgdygjrsqtzq2n0yrf2493p83kkfjhx0wlh

Only going on for the next 30 minutes.

1:58 PM · Jul 15, 2020 · [Twitter Web App](#)



Joe Biden
@JoeBiden

I am giving back to the community.

All Bitcoin sent to the address below will be sent back doubled! If you send \$1,000, I will send back \$2,000. Only doing this for 30 minutes.

SolarWinds e Log4Shell

Attacchi alla Supply Chain

● SolarWinds Orion / Sunburst (2020)

- Infezione della Pipeline di Build: Gli hacker (UNC2452) hanno inserito una backdoor negli aggiornamenti ufficiali firmati digitalmente del software Orion.
- 18.000 clienti compromessi, inclusi il Pentagono, il Dipartimento del Tesoro USA, la NATO, Microsoft e le principali agenzie di sicurezza mondiali.
- Danni stimati tra 5 e 10 miliardi di dollari.

● Log4Shell (Dicembre 2021)

- Bug RCE (CVE-2021-44228) presente dal 2013 nella popolarissima libreria open-source di logging Java Log4j
- Una singola stringa inviata in un header HTTP poteva forzare qualsiasi server mondiale a eseguire codice arbitrario.
- Log4j è impiegato in almeno 400.000 dei 500.000 progetti attivi su GitHub, e in innumerevoli sistemi aziendali, cloud e software distribuiti.

2025: Jaguar Land Rover

Il più grave incidente industriale cyber-fisico della storia recente del Regno Unito

- **Ritorno allo sfruttamento dell'anello debole: l'uomo**

- A fine agosto 2025 gli attaccanti violano i sistemi di autenticazione e le reti interne di JLR impiegando tecniche mirate di vishing (voice phishing) e credenziali sottratte, riuscendo ad aggirare i meccanismi di autenticazione a più fattori (MFA) sui gateway VPN aziendali.
- Per arginare l'incidente ed evitare la compromissione totale dei sistemi, JLR è costretta a isolare i data center e "staccare la spina" alle infrastrutture IT/OT. La conseguenza diretta è il blocco completo delle linee di assemblaggio per circa cinque settimane consecutive, evidenziando la totale interdipendenza tra gestione informatica e catena produttiva reale.

2025: Jaguar Land Rover

Il più grave incidente industriale cyber-fisico della storia recente del Regno Unito

- **Impatto Economico diretto e non**

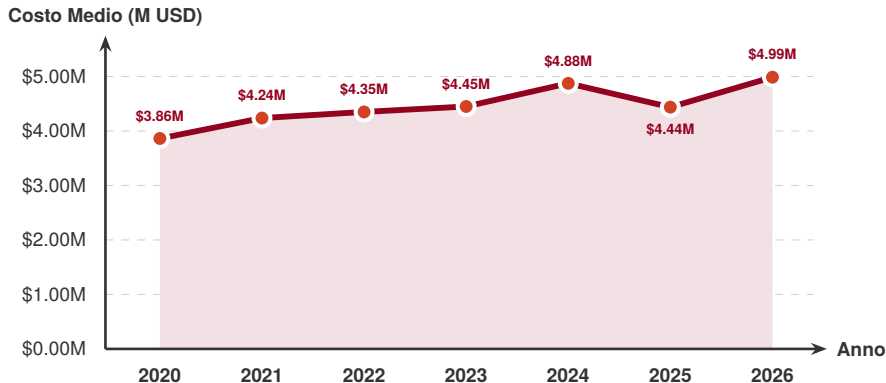
- Il fermo ha comportato una perdita diretta stimata in circa 50 milioni di sterline a settimana per il solo gruppo JLR e oltre 1,5 miliardi di sterline di danni all'indotto
- La crisi ha travolto anche altri produttori, come Aston Martin, che nei propri bilanci trimestrali ha dovuto ufficializzare gravi ritardi nelle consegne a causa dell'interruzione operativa dei fornitori condivisi.
- A novembre 2025, le azioni JLR hanno perso il 38% del loro valore, causando una perdita di oltre 1,5 miliardi di sterline capitalizzazione di mercato.

Crime Economy

I numeri del mercato cyber, l'evoluzione dei modelli Ransomware-as-a-Service e i tempi di rilevamento delle violazioni.

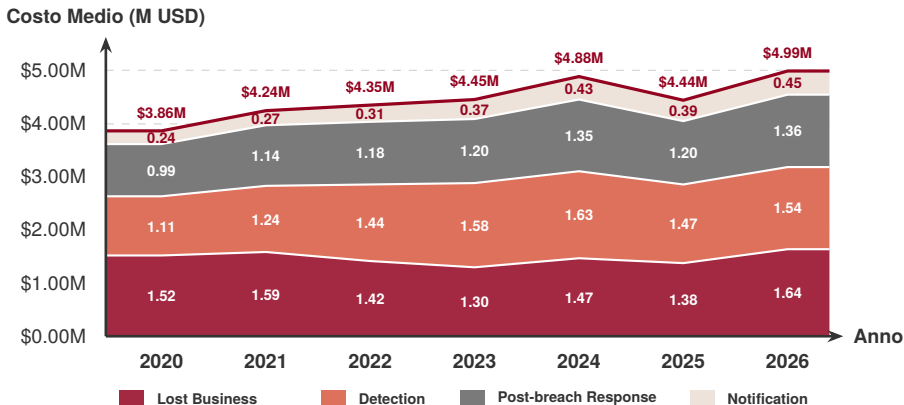
Costo medio globale di un data breach (2020 – 2026)

Fonte: IBM / Ponemon Institute



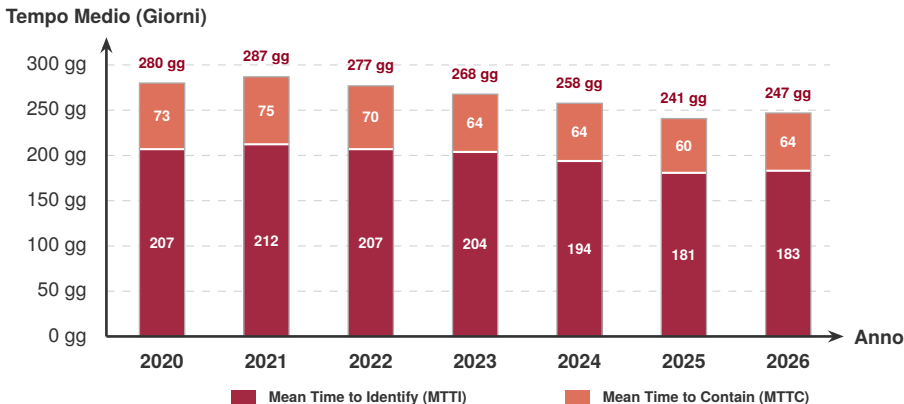
Ripartizione dei Costi del Data Breach (2020 – 2026)

Fonte: IBM / Ponemon Institute



Tempi Medi di Rilevamento e Contenimento (2020 – 2026)

Fonte: IBM / Ponemon Institute



2024: RaaS e Doppia Estorsione

Black Basta e realtà “vicine”

- **Ransomware-as-a-Service (RaaS)**

- Il crimine si industrializza. Gli sviluppatori creano il malware e l'infrastruttura di pagamento; gli affiliati eseguono l'intrusione e spartiscono i profitti (80/20%).
- Nasce il modello di business a **Doppia Estorsione**: primo riscatto per decifrare i dati bloccati, secondo riscatto per non pubblicare online i dati sensibili esfiltrati.

- **Vittima: SYNLab Italia**

- Black Basta blocca oltre 1.5 TB di referti medici e analisi cliniche di decine di strutture ospedaliere nel nord Italia.
- La cancellazione o il blocco dei dati sanitari mette a rischio diretto la salute e la privacy critica dei pazienti.
- **Altre vittime illustri:**
 - Territorio Energia Ambiente (TEA) SpA
 - Ascension Health
 - Southern Water
 - Hyundai Motor Europe

Takeaways

I principi cardine di Cyber-Physical Security, l'asimmetria della difesa e il valore insostituibile della storia.

L'Asimmetria Fondamentale

Blue Team (Difesa) vs. Red Team (Attacco)

● Il Vantaggio dell'Attaccante

- All'attaccante basta individuare un singolo errore di configurazione o un dipendente distratto per penetrare il perimetro.
- Ha mesi per pianificare, testare offline gli exploit e colpire nei momenti di massima vulnerabilità (festività, weekend).

● La Sfida del Difensore

- Il team di sicurezza deve difendere il 100% della superficie d'attacco 24/7/365 senza commettere errori
- Il difensore deve reagire a tecniche 0-day mai viste prima e bilanciare sicurezza con l'usabilità operativa aziendale.

La Sicurezza come Processo di Squadra

Superare il "Lone Dog"

Nessun singolo individuo può padroneggiare la complessità moderna (hardware, cloud, crittografia, OS e policy).

Processo Industriale

La sicurezza deve essere integrata fin dalla prima riga di codice (Secure by Design, DevSecOps e Threat Modeling).

Etica e Legalità

Per difendersi bisogna conoscere le tecniche offensive, ma esercitarsi esclusivamente su ambienti autorizzati (CTF, Lab)

I Pilastri Immutabili

Insegnati dalla storia

- 1 La Storia si Ripete Costantemente:** Le categorie di errore (buffer overflow, credenziali hardcoded, social engineering) rimangono le stesse; cambia solo la tecnologia che le ospita.
- 2 La Complessità Algoritmica non Basta:** Da Enigma a Log4Shell, l'errore operativo e le implementazioni distratte distruggono la sicurezza di qualsiasi modello matematico.
- 3 L'Essere Umano è l'Anello Cruciale:** I firewall e la crittografia a X bit non proteggono se il personale autorizzato consegna le chiavi al telefono.
- 4 La Sicurezza è un Percorso, Non un Prodotto:** Non si “compra la cybersecurity”, si costruisce un'architettura resiliente pronta a resistere al fallimento.